

Vulnerability Management Procedures

Purpose

Room Clarity identifies, prioritizes, remediates, and verifies vulnerabilities in application code, dependencies, deployment configuration, and third-party integrations.

Inputs

- SAST results from CodeQL, Semgrep, or equivalent.
- DAST results from OWASP ZAP baseline or equivalent.
- `npm audit --omit=dev` dependency results.
- Cloud provider alerts.
- Zoom Marketplace review feedback.
- User, tester, or researcher reports.
- Manual review of security-sensitive changes.

Triage

Findings are assigned severity based on exploitability, affected data, user impact, and exposure.

- Critical: fix or mitigate before external beta access continues.
- High: fix before beta expansion or within seven days.
- Medium: fix within thirty days or before marketplace publication.
- Low: track for planned hardening.

Remediation

Remediation may include code changes, dependency updates, configuration changes, credential rotation, access revocation, additional tests, or documentation updates.

Verification

Each remediated vulnerability should be verified using the same class of evidence that found it when possible:

- Re-run SAST for static findings.
- Re-run DAST for deployed endpoint findings.
- Re-run dependency audit for vulnerable packages.
- Add targeted tests for regressions involving access control, webhook verification, token handling, parsing, or model-output validation.